

Internal API Security, Gateway Auth & Secrets Management

CLASSIFICATION / ACCESS LEVEL: ENGINEERING & INFOSEC

This document establishes the security guidelines for service-to-service communication, secret rotation, and API authentication.

API Gateway & Token Authentication: External traffic is routed through Kong API Gateway. All incoming client requests must present a cryptographically signed OAuth2 / OIDC JWT token issued by our central identity provider.

Rate Limiting Rules: Standard public API endpoints are throttled to 1,000 requests per minute per tenant. Burst allowances up to 2,500 requests per minute are granted to enterprise tiers.

Internal Service-to-Service Security: All internal pod-to-pod communication is encrypted in transit using Mutual TLS (mTLS) enforced by Istio service mesh.

Secret Rotation Policy: All API keys, database credentials, and symmetric encryption keys must be managed in HashiCorp Vault. Vault rotates production database credentials every 90 days automatically.